

「XSS対応 脆弱性テスト計画」レビュー結果（抜け・問題点）

2026-10-07

- 対象資料: [XSS対応_脆弱性テスト計画.xlsx](#)（2026-10-06 作成、全 11 シート・テスト行 1,476 行）
- 突き合わせに使ったもの
 - 検証環境ソース（2026-05-08 時点のスナップショット、[source/stg-src](#)）
 - AppScan 診断結果サマリー（2026-03-24 実施、[attachments/03_01_...xlsx](#)）
 - 9/28 の検出方法レビュー（[detection-method-review-20260928.md](#)、付録 A-1～A-18・B-1～B-9・C-1～C-3）
 - 関連チケット（EDU_RB_DEV-40 / 46 / 47 / 48）
- 前提: 修正後のコード（NBR-240-secure ブランチ）は手元にありません。「一覧に無い」と書いた箇所は 5/8 時点のソースとの比較です。修正ブランチで削除済みのファイルは該当しないので、「要確認」として読んでください。

1. 概要

- 方針（文脈別の攻撃文字列、入口別の表示先、F-10 の自動追跡、「対応しない」とした項目の再確認）は妥当で、9/28 レビューで挙げた抜け（A-1～A-18）と過剰適用（B-1～B-9）は、ほぼすべて重点項目（E-01～E-47）に入っています。
- 一方で、このまま実施すると「**全行 OK なのに ExC の再診断で指摘が出る**」可能性が残る点が 6 つあります（2 章）。
 - 網羅の単位が「入力欄のあるテンプレート」で、URL で到達できる PHP ファイル単位の突き合わせが無い
 - 一覧を作った基準ソース（ブランチ・時点）が書かれていない
 - 入力チェックで弾かれた項目は、表示側が未検証のまま OK になる
 - どの行をどの権限のアカウントで実施するかが無い
 - F-10（自動追跡）の中身と、日程・担当・工数が未定義で、完了条件がこれに依存している
 - 検証環境で攻撃文字列を保存することの副作用（メール送信・他の検証作業・復元方法）の手当てが無い
- 過去指摘との対応では、**AppScan 指摘 16 件をパラメータ単位で再現するテストが無いことと、重点項目に全量一覧 No.48・49 が無い**ことが抜けです（3 章）。
- テストセットの割当では、**数値・日付・hidden（S6・S7・S11）に単一引用符とコメント脱出の文字列が入っていない点**が実害につながります。AppScan 指摘 16 件には日付とフラグの項目が含まれていました（4 章）。

2. 計画の成立に関わる問題（優先して直したい点）

2.1 URL で到達できるファイル単位の突き合わせが無い

7 章の洗い出しは「ビュー・テンプレートの入力欄」が起点です。ExC（AppScan）は URL を起点にクロールして全パラメータに注入するため、入力欄を持たない処理用ファイルは一覧から漏れます。5/8 時点のソースで PHP ファイル名と一覧の URL を突き合わせると、次のとおりでした。

範囲	PHP ファイル数	一覧の URL に無い数
受講者サイト（ alfproduct/public ）	175	104
商品管理（ alflearning-cms/alfproduct ）	115	55

同じテンプレートを使う処理ファイルは既存の行で実質カバーされるものもありますが、次のものはどのシートにも対応する行が見当たりません。

受講者サイト

分類	ファイル	補足
公開領域内の退避コード	<code>/exam/backup/</code> （19 本）、 <code>/exam2/backup/</code> （12 本）、 <code>/mypage/lesson_list2_test.php</code> 、 <code>/exam2/*_mst.php</code> ・ <code>*_review.php</code> （6 本）	E-08 の検索パターン（ <code>*_dev</code> ・ <code>*_test</code> ・ <code>*.bak</code> など）に「 <code>backup/</code> ディレクトリ」が入っていません。修正前のコードがそのまま動く可能性があります
SSO の入口	<code>/login/login_sso.php</code> 、 <code>login_sso_new.php</code> 、 <code>sso_auth_callback.php</code>	G-10 は連携データの確認のみ。URL パラメータへの注入と戻り先の行がありません
決済	<code>/settlement/end*.php</code> （14 本）、 <code>member_card.php</code> 、 <code>member_card_regist.php</code> 、 <code>order_regist.php</code> 、 <code>order_passport_user.php</code> 、 <code>araigae_upload.php</code> ・ <code>araigae_download.php</code>	一覧は <code>index</code> ・ <code>alert_passport</code> ・ <code>payment_bank</code> ・ <code>payment_card</code> の 4 画面のみ。E-05 は <code>payment_*</code> の確認用出力だけが対象です
ファイル出力	<code>/mypage/receipt_download.php</code> 、 <code>ticket_download.php</code> 、 <code>/product/download_all.php</code> 、 <code>download_android.php</code>	領収書・受講証は氏名が出る表示先です（G-01 に「領収書」とあるが行が無い）
Ajax・その他	<code>/player/bookmark.php</code> 、 <code>bookmark_delete.php</code> 、 <code>insert_report_user_video_viewed.php</code> 、 <code>/product/player_frame.php</code> 、 <code>/top_product_now.php</code> 、 <code>/maintenance/ethic_treaning.php</code> 、 <code>/inquiry/send.php</code>	応答に入力値が反射するかの確認が必要です

商品管理・CMS

分類	ファイル	補足
CSV・PDF 出力	各機能の <code>csv.php</code> （11 本）、 <code>report_product/csv_file.php</code> ・ <code>csv_file_utf.php</code> 、 <code>mailmagazine/csv_send_user.php</code> ・ <code>csv_sended_user.php</code> 、 <code>amount_order/pdf.php</code>	「CSV・PDF で確認」は各行の備考にありますが、出力ファイル側の行がありません（4.4 参照）
登録・削除・アップロード処理	<code>upload*.php</code> ・ <code>delete*.php</code> （14 本）、 <code>inquiry/status_regist.php</code> 、 <code>product_live/approval_exe.php</code>	<code>approval_exe.php</code> は EDU_RB_DEV-46（SQL インジェクション）の対象です
バッチ	<code>alfproduct/cron/</code> （6 本）	ブラウザから到達できるかの確認が必要です
退避・開発用	<code>report_product/info_dev.php</code> 、 <code>report_all/index.php</code>	一方で <code>_info.php</code> ・ <code>__info.php</code> は一覧に入っています（2.2 参照）
CMS コントローラ	<code>File_container</code> （公開メソッド 6 本。ID・ファイル名を URL で受け取る）、 <code>Api_stream_request</code> 、 <code>Bat*</code> ・ <code>Once_bat*</code> （27 本）	Bat 系はファイル内に「コマンド実行のみ」に限定する判定が見当たりません。 <code>Bat_mail</code> は画面へのエラー表示を有効にしています。URL で到達できるか要確認
CMS エラー画面	<code>issue_error.php</code> ・ <code>book_library_error.php</code> ・ <code>course_class_error.php</code> ・ <code>material_error.php</code> ・ <code>teacher_error.php</code>	エラー文言をエスケープせずに出力し、戻り先 URL を <code>onClick</code> の中に出力しています。エラー文言に入力値が入る経路があるか要確認
API	<code>alflearning-api</code> の <code>Csv_download</code> ・ <code>Login</code> ・ <code>Top</code> ・ <code>Sso_update_profile</code> ・ <code>Elm_api_test</code>	G-10 は SSO・Stream_request のみ
別ディレクトリ	<code>alfproduct/admin/</code> （ <code>testlogin</code> を含む）	公開されているか要確認

提案:「URL で到達できる全ファイル（コントローラの公開メソッドを含む）」の一覧を機械的に作り、各ファイルに「一覧のどの行でテストするか」または「対象外の理由」を対応づけた表を付録に追加してください。この表が空欄なしになることを完了条件に入れると、網羅の根拠になります。

2.2 一覧を作った基準ソースが書かれていない

- 7 章に「コードから抽出」とありますが、どのブランチ・どの時点のコードかが書かれていません。検証環境に実際に置かれているコードと一致していることの確認手順も必要です（E-39 は本番との差分確認のみ）。
- 一覧に `/search/index20260323.php`（13 行）、`report_product/_info.php`・`__info.php`（各 2 行）が入っています。退避ファイルが洗い出し元に混ざっています。「削除する（E-08 で 404 を確認）」のか「残すのでテストする」のかを決めて、行を整理してください。

2.3 入力チェックで弾かれた項目の表示側が未検証になる

- メールアドレス・数値・日付・URL・桁数制限のある項目は、攻撃文字列が保存前に拒否されます。この場合「拒否されたので OK」となり、表示側のエスケープは確認されないまま残ります。F-10 もマーカーが保存できた項目しか追跡できません。
- 別の入口（CSV 取込・SSO・バッチ・過去データ）からは同じ列に値が入るため、ExC が入口を変えると検出されます。S4（URL）には「DB に直接保存された値でも確認」とありますが、S5・S6・S7 と桁数の短い項目にはありません。
- 攻撃文字列はマーカー込みで 40 文字を超えます。桁数で切り詰められた場合、または保存エラーになった場合の扱いが判定基準にありません。

提案: 判定に「入力拒否（表示側は未検証）」を追加し、該当した行は DB への直接投入で表示側を確認する手順を決めてください。短い項目用の文字列（例: `"<<svg/onload=alert(1)>"` より短いもの）も付録に追加が必要です。

2.4 権限（アカウント）が行に割り当てられていない

- 6 章に「管理者（日弁連・単位会・各権限）、受講者、未ログイン」とありますが、1,372 行（CMS・商品管理・受講者サイト）のうち、実施する権限を書いた行は 0 件です。
- 権限によって表示される画面・項目が変わります。また「単位会の管理者が登録した値を、日弁連の管理者が見る」経路（下位権限から上位権限への格納型）は、受講者→管理者と同じく重要ですが、完了条件 4 には入っていません。
- 未ログインでの直接アクセス（ログイン画面へ戻るか、戻り先に値が出るか）も、F-01 の 1 行だけです。

提案: 「入力する権限」「表示を確認する権限」の列を追加し、少なくとも重点項目と入口別の表示先（G-01～G-12）には組み合わせを明記してください。

2.5 F-10（自動追跡）の中身と、日程・担当・工数が無い

- 完了条件 3 と、限界③～④の補完が F-10 に依存していますが、F-10 は 1 行の説明だけです。次の点が未定義です。
 - クロールする URL の決め方（リンクをたどるだけでは、ポップアップ・Ajax・クリックで開く表示・直接 URL の画面に届きません）
 - 権限ごとのログイン状態での巡回
 - 削除・メール送信・決済・バッチ起動などの操作をクロール対象から外す方法
 - スクリプト実行の検知方法（alert はダイアログを閉じないと処理が止まります。画面を止めない検知用の文字列を別に用意する方が自動化しやすいです）
- 1,476 行 × セットあたり十数種類の文字列 × 複数の表示先で、手作業では実施できない量です。9 章は段階だけで、期日・担当・工数・ExC の再診断日からの逆算がありません。
- 行に「実施日・実施者・環境・ブラウザ・権限・証跡の場所・再テスト履歴」の列がありません。1 行に複数の文字列を適用するため、NG の内訳が備考欄の自由記述になり、再テストの追跡が難しくなります。

2.6 検証環境で実施することの副作用

- メール送信:** メルマガ（G-11）、問い合わせの自動返信（G-03）、会員登録・パスワード再発行（G-04）、通知バッチは、実在のアドレスへ送信される可能性があります。送信先の制限方法を準備に入れてください。
- 他の検証作業への影響:** 画面全体を覆う文字列（P11 の `position:fixed`）、自動遷移（`meta refresh`）、全画面共通の表示（通知バナー・サイドバー・カテゴリ名）に保存した alert は、同じ検証環境を使う他の作業者の画面も止めます。実施時間帯の調整が、専用データ（専用の学校・商品）への限定が必要です。
- 復元方法:** 「テスト後に削除・復元」とありますが、通知・自動投稿のお知らせ・セッション・ログにも値が残ります。項目ごとの削除ではなく、実施前の DB バックアップからの復元を手順にする方が確実です。
- 経路:** 受講者サイトの本番は CDN 経由です。検証環境の経路に WAF・CDN があると、攻撃文字列がアプリに届く前に遮断され、誤って OK になります。ExC が診断する経路と同じ経路で実施することを環境欄に明記してください。
- 6 章の「受講者サイト・WordPress: 検証環境の URL を記入」が未記入です。

3. 過去の指摘との対応の抜け

3.1 AppScan 指摘 16 件をパラメータ単位で再現する行が無い

- ExC の再診断は、まず前回と同じ 16 件（反射型 6・格納型 10）を確認します。計画では E-01 の 1 行にまとまっており、内容は「ソースの全文検索」と「SQL エラーの誘発」です。
- 前回のリクエスト（検索語・開始日・終了日・公開状態・無料フラグなど、指摘されたパラメータそれぞれ）に、AppScan と同じ形の文字列（`--><script>...`）を送り、応答に出ないことを確認する行が必要です。格納型は「一度送信 → 別画面へ移動 → 戻る → ログインし直す」の後も確認してください（検索条件がセッションに残ることが原因でした）。
- 同じ SQL 出力があった倫理研修商品一覧・ライブ研修一覧・倫理研修講座一覧（9/28 レビュー A-18）も、画面ごとに行を分けた方が確実です。

3.2 重点項目に全量一覧 No.48・49 が無い

- 重点項目は No.47（E-44）の次が No.50（E-45）です。付録の件数も「No.1〜54 → 47 行」です。まとめた項目（No.1・2、No.11・37、No.29〜31、No.33・34、No.52〜54）を除くと、No.48・49 だけが対応する行を持ちません。
- 意図的に外したのであれば、理由を記載してください。

3.3 過去指摘との対応表が無い

- AppScan 16 件、全量一覧 No.1〜54、9/28 レビューの A・B・C 各項目が、どのテスト行で確認されるかを 1 枚にまとめた表があると、ExC・日弁連側への説明と抜けの確認に使えます。
- 私の方で 9/28 レビューの項目と突き合わせた範囲では、A-1〜A-18・B-1〜B-9・C-1〜C-3 は重点項目に入っていました。ただし C-1（HTMLPurifier）の E-38 は「本番サーバー」とだけあります。本番は Web01〜04 の 4 台構成で、プログラムとキャッシュ用ディレクトリは各サーバーに個別にあるため、**4 台それぞれ**で確認する手順にしてください。

3.4 XSS 以外の既知の指摘の扱いが書かれていない

資料名は「脆弱性テスト計画」ですが、対象は XSS です。次の既知の指摘は対象外であること（または別計画で確認すること）を 1 章に明記してください。P14（SQL の記号）や F-06・F-07・F-09 で一部に触れているため、範囲が曖昧に見えます。

指摘	チケット	この計画での扱い
ボディ・パラメーターをクエリーで送信（AppScan 受講者 No.6・管理者 No.7）	EDU_RB_DEV-40	記載なし
ライブ研修「承認」処理の SQL インジェクション	EDU_RB_DEV-46	記載なし（ <code>approval_exe.php</code> は一覧にも無い）
CSV 出力スクリプト群（使われていないコード）	EDU_RB_DEV-47	E-08 の検索パターンに該当しない
画像表示のパス指定	EDU_RB_DEV-48	E-46・F-08 で確認
CSRF、COOP・CORP・COEP ヘッダー（ExC 判断で対応不要）	—	F-07 の「方針どおり」の方針が未定義。対応不要とした項目を NG にしない基準が必要

4. テストセット・攻撃文字列・判定基準の問題

4.1 数値・日付・hidden に、単一引用符とコメント脱出が入っていない

セット	現在の文字列	足りないもの
S6 数値・ID・選択値（218行）	P19 のみ	P19 に含まれる XSS 用の文字列は <code>"><svg/onload=...></code> （二重引用符）だけです
S7 日付・日時（57 行）	P19・P02・P13	単一引用符（P03）、コメント脱出（P06）、JavaScript 文字列（P05）
S11 hidden・改ざん（136 行）	P19・P02・P05・P08・P17	単一引用符（P03）、コメント脱出（P06）

- 付録の P03 に「CMS の入力欄は単一引用符で囲む箇所が多い」と書かれています。hidden・プルダウン・日付欄の再表示も同じ書き方のはずです。
- AppScan 指摘 16 件の原因は HTML コメント内への出力で、対象には日付とフラグが含まれていました。同じ形の出力が他に残っていた場合、S6・S7・S11 では見つけれられません。
- 提案:** S6・S7・S11 に P02・P03・P05・P06 を追加してください。

4.2 URL から入る値の文字列が足りない

- S8（検索条件）に P12（URL エンコード・全角など）が入っていません。GET で反射する値に最も関係する文字列です。
- 二重エンコード（`%253Cscript%253E`）が P12 にありません。
- パラメータ名**への注入（`?"><script>=1`、`search[<svg/onload=...>]=1`）がどこにもありません。AppScan は値だけでなく名前にも注入し、送信ボタン名を含む全パラメータを対象にします。
- JavaScript の中に引用符なしで出る値（`var id = 値;`）用の文字列（`1;alert(1)`、`1-alert(1)-1`）と、バッククォートで囲む箇所用の文字列（`${alert(1)}`）が P05 にありません。

4.3 「エスケープ処理が見当たらない表示」の行が、通常の表示行と同じ扱いになっている

- 備考に「★テンプレート上、エスケープ等の修飾子が見当たらない」とある行が 191 行あります（CMS 11・商品管理 47・受講者サイト 133）。未対策の候補そのもので、最優先で確認すべき行ですが、種別もセットも通常の表示行と同じ S12 です。
- この中には、意図的に HTML を出力する値（`return.html`・`return.formhtml` など）とタグを許可する項目が含まれます。S12 の期待結果は「入力した文字がそのまま文字として表示される」なので、これらの行は期待結果と合わず判定できません。
- 受講者サイトのシートは S3（タグ許可）が 0 行です。商品説明・備考・設問などのタグ許可項目の表示は、重点項目（E-29・E-31）だけで確認する形になっています。一覧の該当行のセットを S3 相当（表示側）に直してください。
- WordPress の D-0001（トップのお知らせ）も S12 ですが、備考は「URL は内部リンクに切り替わる」で、期待結果と一致していません。
- 提案:** ★行を「未エスケープ候補」として別の種別にし、行ごとに「文字として表示」「許可タグ方式」「意図的な HTML（値の部分だけエスケープ）」のどれを期待するかを先に決めてください。

4.4 CSV・メール・PDF の出力側の行が無い

- P16（CSV の式）は S1～S12 のどのセットにも入っておらず、G-06・G-08・E-43（取込側）でしか使われません。氏名・商品名などに `=1+1` を登録して**各 CSV 出力を開く**確認が、行として存在しません（CSV 出力は 2.1 のとおり 15 本以上あります）。
- 式として実行されないことを OK 条件にする場合、現在の出力がその対策をしているかを先に確認してください。対策が無ければ全 CSV が NG になります。XSS の範囲外とするなら、その旨を明記した方がよいです。
- メールは、送信ライブラリが HTML 形式に対応しています。実際に HTML 形式で送っているメールがあるかを確認し、無ければ「テキスト形式のため対象外」と根拠を書けます。件名・差出人名への改行（ヘッダー注入）は G-11 のみで、問い合わせ・会員登録のメールには記載がありません。
- PDF（注文の PDF、領収書、受講証、印刷用画面）は G-01 の表示先に名前があるだけです。

4.5 判定基準が、タグ許可項目と入力拒否の項目に当てはまらない

- OK 条件④「攻撃文字列が要素・属性として出現しない」は、タグ許可項目では許可タグが要素として出るため、そのままでは使えません。「許可リスト外の要素・属性・URL の種類が 0 件」という基準を別を書く必要があります。
- S3 の期待結果は「実行できるものは取り除かれる（文字としても出ない）」ですが、許可タグ方式の設定によっては、取り除かずに文字として表示する場合があります。実装の設定に合わせて期待結果を確定してください。
- OK 条件④「入力したとおりに表示される」は、拒否が期待される S4～S7 には当てはまりません（2.3 の「入力拒否」の判定と合わせて整理）。

4.6 受講者のファイル提出の入口が一覧に無い

- E-20（課題確認の提出ファイル名）と G-02 は、受講者サイトからのファイル提出が前提です。受講者サイトのシートは S9（ファイル）が 0 行で、G-02 の URL `/issue` に当たるディレクトリは 5/8 時点のソースにありません。
- どの画面から提出するのかを特定して行を追加するか、現在は提出できない機能であれば、既存データでの表示確認に切り替えてください。

5. その他（軽微・確認事項）

- 機能名・ページ名の仮称:** ページ名がファイル名のままの行が 100 行あります（CMS 48・商品管理 10・受講者サイト 42）。「人が補正する」とありますが、担当と期限がありません。
- 件数の説明:** 付録の「CMS 全 29 コントローラ」に対し、シートの機能は 33 です。また「485 入力項目 → 483 行」「647 入力項目 → 481 行」の差（統合・除外の内訳）が書かれていません。網羅の根拠として問われる数字です。
- WordPress:** 15 行は手作業の列挙です。テーマのファイル一覧との突き合わせ（2.1 と同じ対応表）があると根拠になります。
- 本番で行う確認:** 「本番は閲覧のみ」とありますが、本番で行う項目（消し忘れファイルの到達確認、確認用出力の有無、応答ヘッダー、HTMLPurifier の状態）を一覧にしておく必要があります。検証環境と本番にはコードの差があるため、検証環境の OK がそのまま本番の OK にはなりません。
- データ修正（E-36）:** 「44 件」は検証環境の件数と思われます。本番 DB では件数が異なる可能性があるので、本番実行前の件数確認を手順に入れてください。
- 正常系の回帰:** xss_clean の除去、form_helper の標準版への戻し、データ修正は、通常業務の表示・保存にも影響します。通常の業務操作の回帰テストを、この計画に含めるか別計画にするかを明記してください。
- 応答ヘッダー（F-07）:** 5/8 時点の設定ファイルでは、`X-Content-Type-Options: nosniff` は受講者サイト側にあり、CMS 側には見当たりません（サーバー設定で付けている可能性あり）。E-45（JSON 応答）の期待結果が nosniff を前提にしているので、先に現状を確認してください。
- ブラウザ:** Safari (iOS) を実機で行うか、PC での表示切替で代用するかが書かれていません。
- F-10 の初出:** 1 章の方針⑥で説明なく「F-10」が出てきます。3 章の構成表に 1 行説明があると読みやすくなります。

6. 修正の優先順位（提案）

順	内容	該当
1	AppScan 16 件のパラメータ単位の再現テストを追加	3.1
2	S6・S7・S11 に P02・P03・P05・P06 を追加、パラメータ名への注入を追加	4.1・4.2
3	URL で到達できる全ファイルと一覧の対応表を作成（退避ディレクトリ・決済・SSO・CSV・バッチ・エラー画面）	2.1・2.2
4	★行（191 行）の期待結果を行ごとに確定	4.3
5	「入力拒否（表示側未検証）」の判定と、DB 直接投入の手順を追加	2.3
6	権限の列、実施記録の列を追加	2.4・2.5
7	F-10 の仕様、日程・担当、検証環境の準備（メール・復元・経路）を記載	2.5・2.6
8	No.48・49、XSS 以外の指摘の扱い、CSV・メール・PDF の範囲を明記	3.2・3.4・4.4